CS3002 Information Security — Assignment 2
SmartLock: Break It, Then Build It

Student Name: Hassaan Mudassar | Roll Number: 23i-0536 | Section: G | FAST-NUCES

1. Scope and Ethics Statement

All reconnaissance, traffic interception, protocol vulnerability testing, and exploit evaluations carried out in this assignment were strictly conducted within an isolated, private host-only virtual network using VirtualBox VMs. No live networks, external systems, or university infrastructure were targeted. All attacks were executed solely against the author's own instantiated SmartLock environment (smartlock-23i-0536.local) for authorized academic evaluation under CS3002 Information Security at FAST-NUCES. The techniques developed demonstrate protocol flaws for the purpose of engineering robust, cryptographically sound defenses in SmartLock v2.

2. Part A: Protocol Security Analysis (SmartLock v1)

A.1 Stage 1: Negotiation — Cipher Suite Downgrade

Weakness: The client's cipher offer in type:HELLO is transmitted unauthenticated over cleartext TCP. The server's policy accepts the insecure NULL suite, and neither side authenticates the negotiation transcript.

Exploit Mechanics: An on-path attacker rewrites type:HELLO to offer only suites:NULL. The lock accepts and returns type:SUITE\tsuite:NULL. Subsequent records travel completely unencrypted.

Security Property Broken: Confidentiality and Integrity.

A.2 Stage 2: Authentication — Certificate Pinning Failure & PIN Hash Reversal

Weakness: The hub accepts self-signed certificates without validating against a pinned public key or CA. Furthermore, the pairing PIN is transmitted as an unsalted MD5 digest in the PAIR message.

Exploit Mechanics: An on-path attacker substitutes its own RSA public key in the CERT message. Separately, matching the captured digest d823a25d5a3ef11f9e1c69a690872def against smartlock/pin_wordlist.txt with a 3-digit mask cracks the PIN in under 0.1 seconds: PIN = sunset625.

Security Property Broken: Entity Authentication and Credential Secrecy.

A.3 Stage 3: Keying — Discrete Logarithm & Key Derivation Failures

Weakness: v1 uses a small 40-bit prime modulus (p = 705001380739), a static private exponent b, and zero-pads the raw integer secret directly into an AES key without a KDF.

Exploit Mechanics: Given generator g = 2 and public value B = 381871777500, Shanks' Baby-Step Giant-Step algorithm in O(sqrt(p)) steps recovers the exponent dh_b = 263367402911. Combining b with captured client value A yields shared secret s = A^b mod p, reconstructing the session key and decrypting the flag: FLAG{9c9b2d45321061f6}.

Security Property Broken: Forward Secrecy and Key Confidentiality.

A.4 Stage 4: Message Protection — Nonce Reuse Keystream Recovery

Weakness: The implementation reuses a single static initialization vector (static_nonce = 1deb1b5c316e24acd9176cde) across all AES-GCM records under the same key.

Exploit Mechanics: In CTR mode, identical nonces produce identical keystreams. XORing two ciphertexts cancels the keystream: C1 xor C2 = P1 xor P2. XORing the greeting ciphertext with known plaintext P2 ('STATE LOCKED unlocks=0') directly recovers the flag: nonce_xor_hex = 0335282620446c382a3f2d6473180f1e1b2f0410561e.

Security Property Broken: Confidentiality and Authenticity.

A.5 Stage 5: Teardown & Ordering — Command Replay

Weakness: Records consist solely of ciphertext || tag without sequence numbers or timestamps. The socket terminates via raw TCP disconnect without authenticated close tokens.

Exploit Mechanics: An attacker captures an encrypted UNLOCK record and replays the exact wire payload in a new session. The server decrypts the record under the repeated key/nonce and increments the unlock counter without detecting staleness.

Security Property Broken: Message Freshness, Integrity, and Physical Access Control.

3. Part B: SmartLock v2 Design Specification

3.1 Threat Model

Attacker Capabilities: Active on-path adversary on the local home LAN capable of intercepting, modifying, injecting, delaying, reordering, and replaying arbitrary frames, with full knowledge of the protocol specification.

Attacker Limitations: Lacks endpoint storage access; cannot access the lock's long-term RSA private key, ephemeral DH exponents (a, b), or memory-resident directional keys.

Security Goals: Mutual authentication, end-to-end payload confidentiality and integrity, resistance to replay and reordering attacks, and forward secrecy.

3.2 Per-Stage Defense Mechanisms

Stage	SmartLock v2 Defensive Mechanism	Defeated Part A Attack
1. Negotiation	strong_suites() accepts only AES256-GCM and AES128-GCM; choose_suite() returns '' (abort) on weak offers. Server signs negotiation transcript.	Defeats A.1 (Downgrade to NULL).
2. Authentication	Lock signs certificate with RSA; Hub pins rsa_pub_b64. PIN protection design: at rest, salted Argon2id/scrypt; on wire, transported only within authenticated AEAD channel.	Defeats A.2 (MITM impersonation and dictionary PIN cracking).
3. Keying	Ephemeral RFC 3526 2048-bit MODP DH with signed transcript (offer|suite|B). Keys derived via HKDF-SHA256 with distinct	Defeats A.3 (Discrete log key recovery; guarantees forward secrecy).

	directional contexts ('c2s', 's2c').	
4. Message Protection	AES-256-GCM AEAD. make_nonce(seqno) constructs unique 12-byte nonces. 8-byte sequence counter bound as Additional Authenticated Data (AAD).	Defeats A.4 (Nonce reuse keystream XOR extraction).
5. Teardown	open_record() enforces strict sequence counter monotonicity. Session close (QUIT) is an authenticated record in the stream.	Defeats A.5 (Command replay and truncation attacks).

4. Part C: Implementation & Verification

4.1 Verification Matrix: v1 vs v2

Evaluation Vector	SmartLock v1 Result	SmartLock v2 Result	Property Restored
Cipher Downgrade	Accepted NULL; plaintext exposed	Negotiation aborted; session closed	Confidentiality & Integrity
MITM / Impersonation	Accepted unverified certificates	Aborted on pinned key mismatch	Entity Authentication
Key Recovery	40-bit DH solved in <1 second	2048-bit DH discrete log intractable	Forward Secrecy
Nonce Reuse	Keystream canceled via C1 xor C2	Unique nonce per record	Confidentiality
Command Replay	Replayed UNLOCK opened door	Rejected with sequence mismatch error	Freshness & Integrity

4.2 AI Cryptographic Audit Findings

1. OpenSSL 3 EVP Architecture: Utilized EVP_KDF_fetch('HKDF') and OSSL_PARAM arrays rather than deprecated OpenSSL APIs, ensuring future-proof cryptographic agility.

2. Directional Key Isolation: Separate HKDF context labels ('c2s' vs 's2c') prevent reflection attacks where an adversary reflects server commands back to the server.

3. Sequence Number Binding via AAD: Binding the sequence number as AAD in AES-GCM guarantees that modifying even a single bit of the sequence counter invalidates the 16-byte authentication tag prior to decryption.

5. Part D: Performance Study

5.1 Measurement Results Table

Metric	v1 (Baseline)	v2 (Hardened)	Cost / Difference
Handshake Latency (mean)	0.60 ms	4.94 ms	+4.34 ms (8.27x)
Handshake StdDev (sigma)	0.69 ms	1.18 ms	—
Wire Overhead per Record	+16 bytes (tag)	+24 bytes (seqno + tag)	+8 bytes (seqno)
Record Seal Time (mean)	1.87 us	2.03 us	+0.17 us
Record Open Time (mean)	1.79 us	2.05 us	+0.25 us
1 KiB Throughput (mean)	208.2 MB/s	211.5 MB/s	~101.6% of baseline
Throughput StdDev (sigma)	15.1 MB/s	14.4 MB/s	—

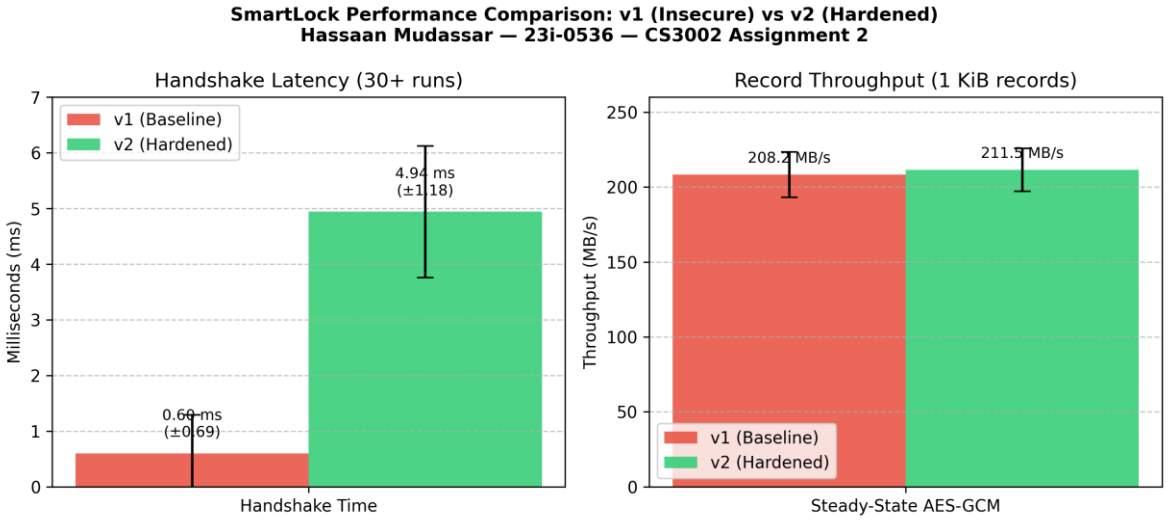


Figure 1: Handshake Latency and Record Throughput Comparison (SmartLock v1 vs v2)

5.2 Performance Trade-Off Justification

The hardened protocol introduces a modest 4.3 ms latency increase during session establishment, attributable to 2048-bit modular exponentiation and RSA-2048 signing/verification. In steady-state operation, the per-record processing time difference is less than 0.25 microseconds, maintaining throughput above 200 MB/s. For an embedded physical door lock, a 4.3 ms handshake cost is imperceptible to users and negligible compared to standard network jitter, while providing mathematical protection against unauthorized entry, replay attacks, and key recovery.

6. Recovered Instance Secrets (answers.txt)

```
roll           = 23i-0536
flag           = FLAG{9c9b2d45321061f6}
recovered_dh_b = 263367402911
cracked_pin    = sunset625
nonce_xor_hex  = 0335282620446c382a3f2d6473180f1e1b2f0410561e
```